

An Implementation Guide for AI-Speed Security

A 12-Month Plan, and What Comes After

Introduction

Security must now operate at AI speed. The window between an attacker's first move and material business damage is no longer measured in weeks. It is measured in hours, sometimes minutes. The security model — governance, authority, technology, and the people who run it — has to close that gap.

This paper sets out a practical implementation plan for an enterprise that has accepted the premise and wants to move. It is written in four phases: what to do in the next three months, what to do in months four through eight, what to complete by the end of the first year, and what to keep building beyond.

The plan is sequenced deliberately. Earlier phases unblock later phases. Skipping ahead is tempting and will fail.

Phase 1 — Act Now (0–3 months)

Outcome by the end of this phase: the organization has made the foundational governance and authority decisions that make everything else possible.

Governance and authority

- **Set the reporting line.** The CISO reports to the CEO, with a mandated quarterly slot at the board, and a written escalation path that does not depend on the CEO being available in the moment. Do this in writing.
- **Rewrite the CISO mandate.** The CISO equips accountable leaders to own their risk. The CISO does not own enterprise risk. Make this explicit in the role description, in the board charter, and in the security charter.
- **Hold the first board conversation on risk appetite.** Get acceptable loss, critical-service prioritization, and the trade-offs the business is willing to make in writing. Without this, every operational decision later will be re-litigated.
- **Establish the governance cadence.** Bi-weekly at the operational layer, monthly at the leadership team, quarterly at the board. Put the meetings on the calendar before you have content for them — the cadence is the operating heartbeat.

Operating model

- **Identify the pre-authored actions** the security function will need to take without asking. The starter list: identity suspension, endpoint isolation, session and token revocation, service degradation. Begin drafting the conditions under which each may be taken.
- **Inventory critical services.** What does the enterprise truly need to keep running? The top five to ten. This is the input to every later prioritization decision.

- **Begin fusing threat intelligence into one operational picture.** Stop running parallel intelligence streams in different tools. Even a rough first version is more useful than three sophisticated ones that never meet.

Technology and data

- **Audit standing privilege.** Find the worst offenders — long-lived admin accounts, shared credentials, service principals with broad scope. Make the list. Do not try to fix it all in three months; that comes next phase. First, know what you have.
- **Enforce phishing-resistant multi-factor authentication** where it is missing on privileged paths. This is the easiest structural improvement available, and the most overdue.
- **Remove long-lived secrets** in the obvious places: source code repositories, configuration files, shared mailboxes. A quick sweep before you build the larger identity story.

People

- **Verify the CISO matches the profile.** Decision engineer, comfortable with pre-authored authority, refuses to own risk, board-fluent. If the current CISO does not match, start the search now. The rest of the plan does not work without the right person in the role.
- **Communicate the shift to the executive team.** The whole leadership team should hear, in one room, what changes about how security operates and what it now expects of them. Authority moves forward in time. Accountability moves with it.

Phase 2 — Short-Term (4–8 months)

Outcome by the end of this phase: the continuous decision loop is operating, pre-authored authority is real, and the technology spine is being rebuilt around identity.

Governance and authority

- **Codify pre-authored authority into written runbooks** signed by the CEO, the General Counsel, and the CISO. One runbook per action, with conditions, evidence requirements, communication paths, and post-action review. Do not over-engineer. This is the single most important deliverable of the year.
- **Run the first live tabletop exercises** that exercise the pre-authored actions end to end. The point is to find the gaps before an adversary does.
- **The bi-weekly governance meeting becomes the operating heartbeat.** Live threat picture in, decisions out, with named owners and dates. If the meeting drifts into status updates, stop it and restart with a tighter agenda.

Operating model

- **Begin measuring decision latency and authority latency as named metrics.** Track them. Report them. Reduce them on a published cadence.
- **Establish the AI agent governance model.** Every non-human actor — copilots, automation agents, integrations — has identity, scope, telemetry, and a lifecycle. Inventory what you have today. Most enterprises will be surprised by the count.
- **Begin participation in collective defense.** Sector information-sharing groups, hyperscaler programs,

peer CISO networks. Move from contact list to operating habit.

Technology and data

- **Stand up a unified telemetry plane** — the security data lake and the relationship-aware graph that sits on top of it. This is the foundation for everything in Phase 3.
- **Roll out conditional access enterprise-wide** and begin moving privileged access to just-in-time, just-enough patterns. Standing admin is the target.
- **Modernize the Security Operations Center.** Agent-assisted triage. Baselines for mean time to detect and mean time to respond. Public targets for both.

People

- **Restructure the security leadership bench** if it does not match the new model. The strongest sub-leaders — Head of SOC, Security Architecture, Threat Intelligence, Regulatory — do the technical work. The CISO operates above them.
- **Train the wider organization** on what pre-authored authority means for them. A user whose session is revoked at 02:00 needs to know, in advance, why and what happens next.

Phase 3 — Mid-Term (9–12 months)

Outcome by the end of this phase: the model is embedded, measured, and producing visible reductions in latency and risk. The SOC has moved from human-run to agent-operated, with humans on the loop, not in it.

Governance and authority

- **External attestation of the governance loop.** Internal audit, or a third party, validates that decisions are being made on the cadence, on the basis of live intelligence, and with traceable outcomes.
- **Annual re-anchoring with the board.** The acceptable loss conversation from Phase 1 is re-done with twelve months of operating data behind it. Adjust the appetite where reality has diverged from assumption.

Operating model

- **The governance loop has produced binding decisions** that visibly changed how the CIO, the CTO, or a business owner operates. If it has not, the loop is theater. Find out why and fix it.
- **Decision latency, authority latency, and organizational misalignment** are reported metrics with reduction targets. They are visible to the board, not only to the security function.

A SOC run by agents, supervised by humans

The graph built in Phase 2 is now the substrate. Three classes of agents operate continuously on top of it. Humans sit on the loop, not in it.

- **Red agents.** Continuous adversary emulation against the live environment. They walk the graph looking for paths the defensive side has not closed. They trigger pre-authored authority conditions to test whether the blue side responds correctly. They update their playbook as new attacker techniques appear. They generate the findings that blue and green work from.

- **Blue agents.** Continuous triage, investigation, and containment. They pull context from the graph in real time, correlate signals across the telemetry plane, and execute pre-authored actions — identity suspension, endpoint isolation, session and token revocation, service degradation — when the conditions match. They hand off to humans only for novel cases and first-of-kind events.
- **Green agents.** Remediation, hardening, and verification. They take what the blue agents contained and turn it into a permanent fix: patch, reconfigure, decommission, rotate. They then re-run the red scenario to confirm the fix held, and close the exposure in the graph. Mean time to remediate becomes a measured operating metric, not a follow-up project.

The human role moves on to the loop. Humans set policy, define the pre-authored conditions, review agent decisions on a cadence rather than in real time, handle the cases the agents escalate, and tune the agents based on outcomes. The team is smaller, more senior, and works on what humans are actually good at — judgment, novelty, edge cases, and the conversations with the rest of the business.

The agents themselves are governed under the AI agent model established in Phase 2: each has identity, scope, telemetry, and a lifecycle. They are not exempt from the rules they enforce.

Technology and data

- **Mean time to detect and mean time to respond have shrunk by at least an order of magnitude** versus the Phase 1 baseline. With agents in the operating seats, "minutes" is a credible target for both, and "seconds" is in reach for the most common attack patterns.
- **Standing admin privilege is at or near zero.** Just-in-time elevation is the default path. Long-lived secrets are gone from production.
- **The security graph drives proactive exposure management.** The team no longer works from a list of alerts; it works from a map of paths an adversary could take — and the red agents are actively walking that map.
- **Business risk and technical exposure are linked in one data layer.** A leader looking at a critical service can see, in one place, the technical exposures that could degrade it.

People

- **The CISO is in the board room on the cadence,** not as a guest. The conversation is about decisions and trade-offs, not about heat maps.
- **The security leadership bench can run the loop without the CISO** for two weeks. If the model collapses when the CISO is on leave, the model is not yet embedded.
- **The SOC headcount changes shape.** Fewer Level 1 and Level 2 analysts; more senior engineers who can build, tune, and supervise agents. Plan the transition deliberately — including how it lands with the existing team. This is the part most organizations underestimate.

Phase 4 — Beyond (12+ months)

Outcome: AI-speed security stops being a transformation program and becomes how the enterprise operates. The same pattern starts spreading.

- **The decision-system pattern spreads beyond security.** Operational risk, fraud, supply chain, and other risk domains adopt the same continuous loop: live signal in, decisions out, pre-authored authority where speed matters.

- **AI agents do more of the execution.** Humans focus on the novel cases, the edge governance calls, and the relationships. The CISO function evolves from decision engineer to decision-system architect for the enterprise.
 - **Collective defense moves from participation to integration.** Shared telemetry with peers and hyperscalers. Coordinated response patterns where regulation allows.
 - **Sovereignty and regulatory posture are managed dynamically** against a changing rule set, not as a once-a-year compliance event.
 - **Continuous talent renewal.** The next generation of decision-engineer security leaders is being developed inside the organization. The bench is real.
 - **The acceptable loss conversation with the board happens every year**, as a working session, not a presentation. The number changes because the business and the threat landscape change.
-

A Closing Note

This plan is sequenced for a reason. Phase 1 is mostly conversation — the reporting line, the mandate, the cadence, the acceptable loss decision. It looks light, and that is the temptation: to skip it and move straight to technology rollouts. Do not. A pre-authored authority playbook with no executive agreement is paper. A modernized SOC reporting through the CIO inherits the latency it was supposed to remove.

Get the governance moves done first, even if they feel like the slowest part. Everything else moves faster afterward.

If a board asks how long this takes, the honest answer is twelve months to a credible operating model, and another twelve to embed it. Anyone selling shorter is selling.